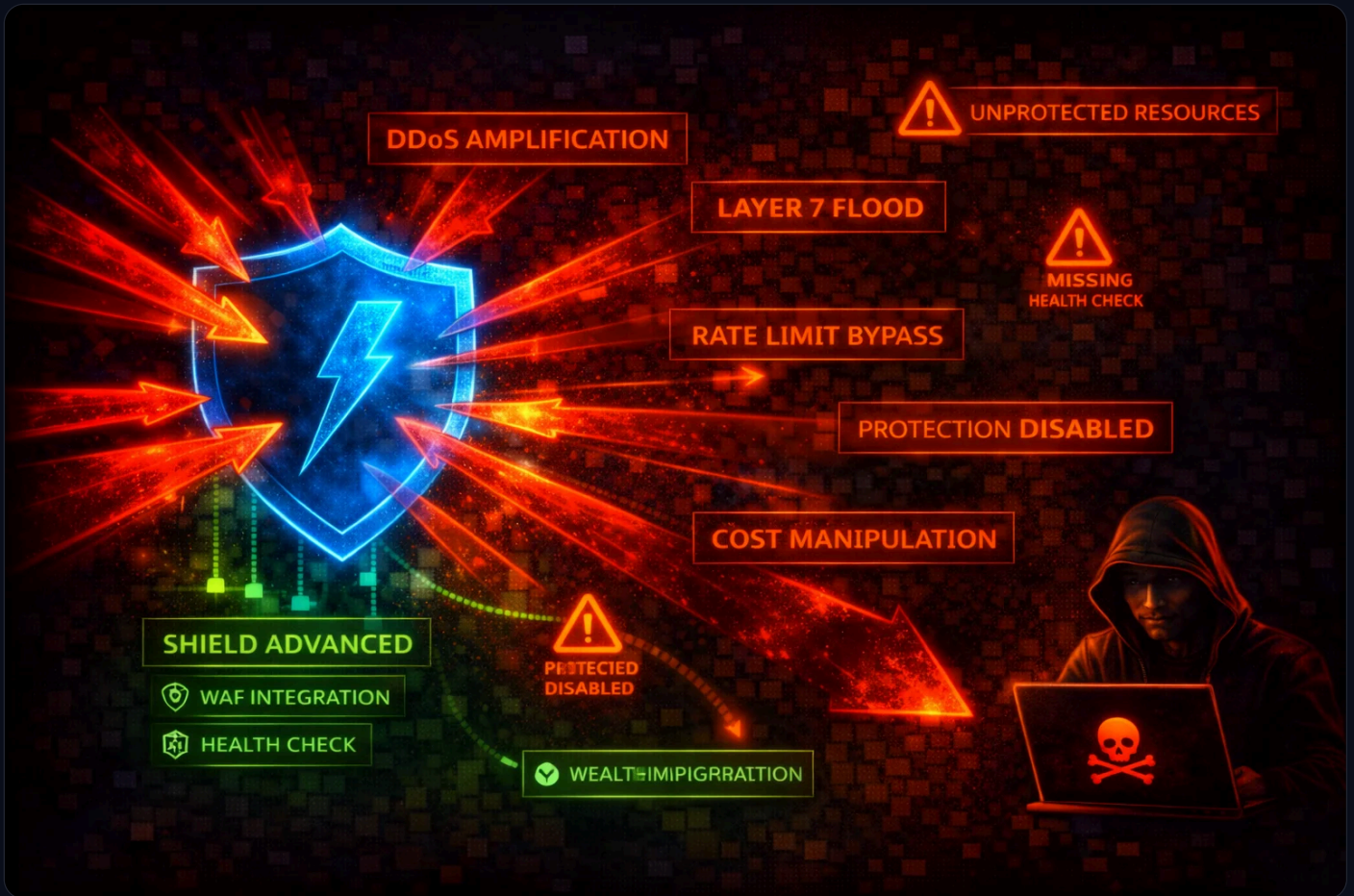




AWS Shield Security

DDoS PROTECTION

HIGH

Risk Level

**Global
(CloudFront, Route
53) + Regional
(ELB, EC2, Global
Accelerator)**

Scope

**Shield Standard,
Shield Advanced,
SRT (API prefix:
DRT), Protection
Groups**

Key Components

**Standard: Free /
Advanced:
\$3,000/month (1-
year commitment)**

Pricing

Service Overview

How Shield Works

AWS Shield provides DDoS protection at two tiers. **Shield Standard** is automatically enabled at no charge for all AWS customers and defends against the most common network-layer (Layer 3) and transport-layer (Layer 4) DDoS attacks targeting resources behind Amazon CloudFront, Amazon Route 53, and AWS Global Accelerator. **Shield Advanced** is a paid subscription that extends protection to Amazon EC2, Elastic Load Balancing, CloudFront, Global Accelerator, and Route 53 with enhanced detection, near real-time visibility, and application-layer (Layer 7) DDoS mitigation. Shield Advanced subscribers get 24/7 access to the AWS Shield Response Team (SRT), automatic application-layer DDoS mitigation via AWS WAF, cost protection (service credits for DDoS-related scaling spikes), health-based detection using Route 53 health checks, and proactive engagement where the SRT contacts you directly when a health check becomes unhealthy during a detected event.

****Attack note:** ** Shield Standard only covers Layer 3/4. Without Shield Advanced, application-layer floods (HTTP floods, DNS query floods) have no automatic mitigation. Attackers who understand this distinction target Layer 7 specifically against Standard-only customers.

DDoS Attack Vectors Shield Addresses

Shield protects against network volumetric attacks (UDP reflection, SYN floods, DNS amplification), transport protocol attacks (SYN/ACK floods, TCP connection exhaustion), and -- with Shield Advanced -- application-layer floods (HTTP request floods, HTTP/2 rapid reset attacks). AWS publicly disclosed mitigating an HTTP/2 rapid reset attack peaking at over 155 million requests per second against CloudFront in August 2023. ---

****Attack note:** ** An attacker does not need to compromise your AWS account to DDoS you. The threat model is external. However, an attacker *with* account access can disable Shield Advanced protections, remove protections from resources, or disassociate health checks to blind detection -- turning an account compromise into a DDoS amplifier.

Security Risk Assessment



Shield Standard is automatic and free, reducing baseline risk. However, organizations running internet-facing workloads on EC2/ELB without Shield Advanced lack application-layer DDoS protection, cost protection, and SRT access. Misconfigured Shield Advanced (missing health checks, no proactive engagement, unprotected resources) creates a false sense of security. The \$3,000/month cost leads many organizations to skip it, leaving them exposed to sophisticated DDoS attacks that bypass Layer 3/4 mitigations.

✖ Attack Vectors

External DDoS Attack Types

- **UDP reflection/amplification** -- Attacker spoofs source IP to trigger DNS, NTP, SSDP, or memcached servers to flood the target with response traffic
- **SYN flood** -- Exhausts TCP connection state tables on the target by sending high volumes of SYN packets without completing the handshake
- **HTTP request flood** -- Overwhelms application-layer resources with legitimate-looking HTTP requests (requires Shield Advanced for automatic mitigation)
- **DNS query flood** -- Floods Route 53 hosted zones with DNS queries to exhaust resolver capacity
- **HTTP/2 rapid reset attack** -- Exploits HTTP/2 stream multiplexing by rapidly opening and resetting streams, consuming server resources

Account-Level Attack Vectors (Post-Compromise)

- **shield:DeleteProtection** -- Attacker with account access removes DDoS protection from critical resources before launching an attack
- **shield:DisassociateHealthCheck** -- Removes health-based detection, blinding Shield Advanced to application degradation
- **shield:DisableProactiveEngagement** -- Prevents the SRT from proactively contacting the organization during detected events
- **shield:DisassociateDRTRole** -- Revokes SRT access to the account, eliminating expert support during an active attack
- **shield:DeleteSubscription (deprecated)** -- The `shield:DeleteSubscription` API is deprecated; cancellation now requires contacting AWS Support. An attacker can use `shield:UpdateSubscription` with `AutoRenew=DISABLED` to prevent subscription renewal instead

⚠ Misconfigurations

Protection Coverage Gaps

- **Internet-facing resources not added to Shield Advanced** -- Shield resources not CloudFront only S
- **No health checks associated with protections** -- Without Advance resulting positive
- **Proactive engagement not enabled** -- SRT detected
- **Emergency contacts not configured** -- SRT during notification
- **Protection groups not defined** -- Without correlate resource

Operational Misconfigurations

- **No WAF web ACL on application-layer resources** -- Shield mitigati web AC active
- **DRT role not granted** -- SRT cannot mitigation if no AssociateDRT
- **DRT log bucket not associated** -- SRT WAF l
- **Using Shield Advanced without Business/Enterprise Support** -- S or SR sub
- **Not using Firewall Manager for multi-account Shield deployment** -- ma lea res

Enumeration

Check Subscription Status

```
aws shield get-subscription-state
```

Describe Shield Advanced Subscription Details

```
aws shield describe-subscription
```

List All Protected Resources

```
aws shield list-protections
```

Describe Protection for a Specific Resource

```
aws shield describe-protection \
  --resource-arn arn:aws:elasticloadbalancing:us-east-1:123456789012:loadbalancer/app/my-alb/12345678
90123456
```

List Recent DDoS Attacks

```
aws shield list-attacks \
  --start-time FromInclusive=2026-01-01T00:00:00Z,ToExclusive=2026-03-30T00:00:00Z
```

Describe a Specific Attack

```
aws shield describe-attack \
  --attack-id a1b2c3d4-5678-90ab-cdef-EXAMPLE11111
```

Describe Attack Statistics

```
aws shield describe-attack-statistics
```

List Protection Groups

```
aws shield list-protection-groups
```

Check DRT Access Configuration

```
aws shield describe-drt-access
```

Check Emergency Contact Settings

```
aws shield describe-emergency-contact-settings
```

Privilege Escalation

Direct Escalation Paths

- shield:CreateSubscription + shield:CreateProtection

- shield:AssociateDRTRole

- shield:AssociateDRTLog

- iam:PassRole + shield:AssociateDRTRole

Indirect Escalation Paths

- shield:DeleteProtection on all resources

- shield:UpdateEmergency

- shield:EnableApplication with permissive WAF rule

Policy Examples

✗ Dangerous -- Overly Permissive Shield Access

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": "shield:*",
    "Resource": "*"
  }]
}
```

Risk: Allows creating/deleting subscriptions, removing protections from resources, revoking DRT access, and disabling proactive engagement. An attacker with this policy can fully dismantle DDoS defenses.

✓ Secure -- Read-Only Shield Monitoring

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ShieldReadOnly",
      "Effect": "Allow",
      "Action": [
        "shield:Describe*",
        "shield:List*",
        "shield:GetSubscriptionState"
      ],
      "Resource": "*"
    },
    {
      "Sid": "ProtectedResourcesReadAccess",
      "Effect": "Allow",
      "Action": [
        "cloudfront:List*",
        "cloudfront:GetDistribution*",
        "elasticloadbalancing:Describe*",
        "route53:List*",
        "globalaccelerator:ListAccelerators",
        "globalaccelerator:DescribeAccelerator",
        "ec2:DescribeAddresses"
      ],
      "Resource": "*"
    },
    {
      "Sid": "CloudWatchMetrics",
      "Effect": "Allow",
      "Action": [
        "cloudwatch:Describe*",
        "cloudwatch:Get*",
        "cloudwatch:List*"
      ],
      "Resource": "*"
    }
  ]
}
```

Why: Grants visibility into Shield protections, attack events, and protected resource status without the ability to modify DDoS defenses. Includes CloudWatch for viewing Shield metrics.

✓ Secure -- SCP to Prevent Disabling Shield Advanced

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "PreventShieldDisable",
      "Effect": "Deny",
      "Action": [
        "shield:DeleteProtection",
        "shield:DeleteSubscription",
        "shield:DisableProactiveEngagement",
        "shield:DisassociateDRTRole",
        "shield:DisassociateDRTLogBucket",
        "shield:DisassociateHealthCheck",
        "shield:DisableApplicationLayerAutomaticResponse"
      ],
      "Resource": "*",
      "Condition": {
        "ArnNotLike": {
          "aws:PrincipalArn": "arn:aws:iam::*:role/ShieldAdmin"
        }
      }
    }
  ]
}
```

Why: Prevents anyone except a dedicated ShieldAdmin role from disabling protections, removing health checks, or revoking SRT access. Deploy as an SCP in AWS Organizations.



Defense Recommendations

Enable Shield Advanced on All Internet-Facing Resources

Add explicit Shield Advanced protections to every CloudFront distribution, Application Load Balancer, Elastic IP, Global Accelerator, and Route 53 hosted zone that serves production traffic.

```
aws shield create-protection \  
  --name "prod-alb-protection" \  
  --resource-arn arn:aws:elasticloadbalancing:us-east-1:123456789012:loadbalancer/app/prod-alb/1234567890123456
```

Associate Route 53 Health Checks for Health-Based Detection

Health checks enable faster, more accurate detection and are required for proactive engagement.

```
aws shield associate-health-check \  
  --protection-id abc123-def456 \  
  --health-check-arn arn:aws:route53:::healthcheck/12345678-abcd-efgh-ijkl-123456789012
```

Enable Proactive Engagement and Configure Emergency Contacts

Allow the SRT to contact you proactively during detected events.

```
aws shield update-emergency-contact-settings \  
  --emergency-contact-list EmailAddress=security@example.com,PhoneNumber=+15551234567,ContactNotes="Security team on-call"
```

```
aws shield enable-proactive-engagement
```

Grant DRT Access with a Scoped IAM Role

Give the SRT the access they need to help during an attack without over-privileging.

```
aws shield associate-drt-role \  
  --role-arn arn:aws:iam::123456789012:role/AWSSRTAccessRole
```

```
aws shield associate-drt-log-bucket \  
  --log-bucket my-waf-logs-bucket
```

Enable Automatic Application-Layer DDoS Mitigation

Requires an AWS WAF web ACL associated with the protected resource.

```
aws shield enable-application-layer-automatic-response \  
  --resource-arn arn:aws:elasticloadbalancing:us-east-1:123456789012:loadbalancer/app/prod-alb/1234567890123456 \  
  --action Block={}
```

Create Protection Groups for Correlated Detection

Group related resources so Shield Advanced can detect distributed attacks across multiple endpoints.

```
aws shield create-protection-group \  
  --protection-group-id "prod-web-tier" \  
  --aggregation SUM \  
  --pattern ARBITRARY \  
  --members arn:aws:elasticloadbalancing:us-east-1:123456789012:loadbalancer/app/prod-alb/1234567890123456
```

Use AWS Firewall Manager for Multi-Account Shield Deployment

In AWS Organizations, use Firewall Manager Shield Advanced policies to automatically protect resources across all member accounts and detect unprotected resources.

Deploy an SCP to Prevent Disabling Shield Protections

Use the SCP example above in AWS Organizations to prevent unauthorized removal of DDoS protections.

Monitor Shield Metrics in CloudWatch

Key metrics to alarm on: DDoSDetected, DDoSAttackBitsPerSecond, DDoSAttackPacketsPerSecond, DDoSAttackRequestsPerSecond in the AWS/DDoSProtection namespace. AWS Shield / Shield Advanced Security Card -- Toc Consulting Always obtain proper authorization before testing. DDoS testing against AWS resources requires prior approval from AWS per the AWS Acceptable Use Policy.

AWS Shield Security Security Card

Always obtain proper authorization before testing